

ANALISI DINAMICA: WannaCrypt0r.exe

1. OBIETTIVO

Fare un'analisi dinamica dell'eseguibile **WannaCrypt0r.exe** presente nella cartella malware della macchina FlareVM. Usare tria.ge (sandbox gratuita accessibile da mail personale) e si può fare affidamento su LLM.

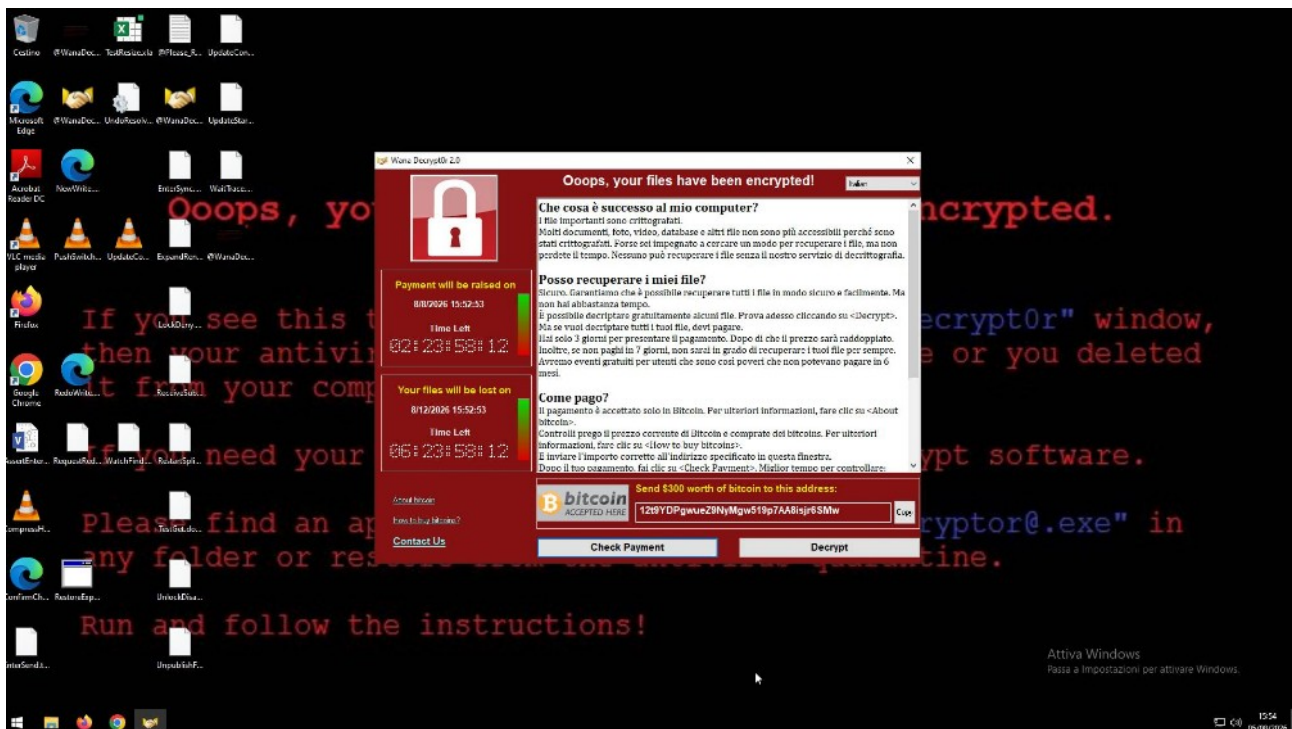
2. SCANSIONE CON TRIA.GE

Su browser di Flarevm è stata cercata la pagina ufficiale della sandbox ed è stata fatta l'iscrizione con gmail. Nella cartella dei malware è stato trovato l'eseguibile per fare l'upload sul sito e avviare la scansione.

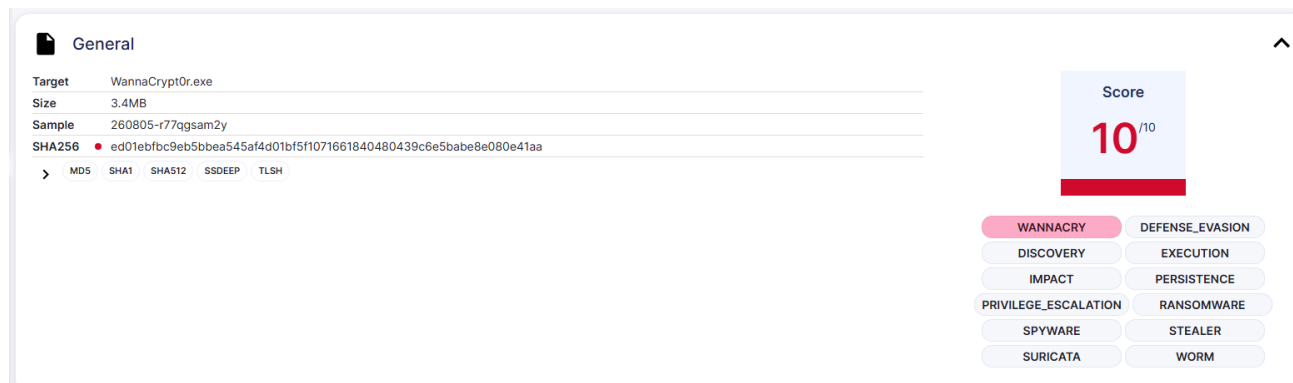
Durante la scansione si ha la possibilità di vedere a schermo quello che succede sul desktop e alla fine compare il report contenente tutte le informazioni ricavate dall'analisi.

3. REPORT E ANALISI DELLA SCANSIONE

Una prima conferma che si tratta di ransomware si ottiene durante l'esecuzione della scansione, poiché nel desktop della sandbox compare il banner che chiede denaro in cambio delle chiavi di decriptazione.



3.1 INFORMAZIONI GENERALI



Tria.ge ha individuato la famiglia di appartenenza del malware (WannaCry), confermando essere un ransomware ad alta pericolosità, infatti il punteggio assegnato è 10/10.

3.2 ANALISI DEL COMPORTAMENTO

L'analisi dinamica condotta sulla piattaforma Tria.ge ha assegnato al campione un **punteggio di pericolosità massimo (10/10 - Critical)**, identificandolo con certezza come appartenente alla famiglia **WannaCry**. Il comportamento del malware si articola nelle seguenti fasi operative:

1 Cancellazione dei Backup (Deletes shadow copies): Il malware elimina le copie di shadow del sistema per impedire il ripristino dei file (rilevate 3 TTPs).

2 Persistenza e Privilegi (Persistence & Privilege Escalation):

- Crea un file nella cartella di avvio automatico (Startup).
- Aggiunge una chiave di registro RUN per avviarsi in automatico.

3 Esecuzione di Componenti Secondari:

- Esegue file .exe estratti (62 IoCs).
- Carica librerie .dll estratte (16 IoCs).
- Esegue uno script VBScript tramite *Windows Script Host*.
- Esegue comandi tramite *cmd.exe*.

4 Modifiche al Sistema e Riscatto (Impact & Ransomware):

- Modifica i permessi dei file e delle directory.
- Modifica lo sfondo del desktop tramite Registro di sistema.
- Usa il servizio *Volume Shadow Copy COM API*.
- Estrae il file di configurazione/istruzioni @Please_Read_Me@.txt nel percorso C:\Users\Admin\AppData\Local\Temp\.

5 Lettura Dati e Localizzazione (Discovery / Stealer):

- Legge i dati utente e di profilo dai browser web (3 TTPs).
- Effettua la ricerca della lingua di sistema (*System Language Discovery*) per identificare la posizione geografica (35 IoCs).
- Elenca i processi in esecuzione e le unità di archiviazione fisiche collegate.

4 Attività di Rete (Suricata):

- Attiva un allarme dell'IDS Suricata per la rilevazione di certificati X.509 legati a nodi della rete Tor (connessione in entrata/C2).

3.3 ANALISI DEI PROCESSI

1 Preparazione dei Permessi e Nascondimento (icacls.exe, attrib.exe)

- **icacls.exe (PID 3220):** Concede i permessi di scrittura e controllo totale a tutti gli utenti su tutti i file (/grant Everyone:F /T /C /Q), sbloccando qualsiasi file protetto per poterlo cifrare senza errori.
- **attrib.exe (PID 3452, 4680):** Imposta gli attributi di sistema e nascosto (+h +s) sulle directory di lavoro e sul Cestino per occultare le tracce del malware.

2 Distruzione dei Backup e Ripristino (cmd.exe, WMIC.exe, vssvc.exe)

- **cmd.exe (PID 1636):** Esegue in una singola riga di comando una serie di strumenti di sistema per cancellare le copie Shadow (vssadmin delete shadows /all /quiet), disabilitare il ripristino di Windows (bcdedit /set ... recoveryenabled no) e cancellare il catalogo dei backup (wbadmin delete catalog).
- **WMIC.exe (PID 3756) & vssvc.exe (PID 4292):** Invocati per eliminare via WMI le copie shadow ed interagire con il servizio *Volume Shadow Copy*.

3 Persistenza ed Esecuzione Script (reg.exe, cscript.exe)

- **reg.exe (PID 808):** Inserisce nel Registro di Windows la chiave Run (con valore lxbzdljmub035) per forzare l'avvio del file tasksche.exe a ogni accensione del computer.
- **cscript.exe (PID 3396):** Esegue in background lo script m.vbs per impostare lo sfondo del desktop e avviare moduli secondari.

4 Comunicazione C2 via Tor (taskhsvc.exe)

- **taskhsvc.exe (PID 5116, 2256):** Processo situato nella cartella TaskData\Tor\ che stabilisce la connessione cifrata verso i server di Comando e Controllo (C2) della rete anonima Tor.

5 Ciclo di Monitoraggio e Interfaccia di Riscatto (taskdl.exe, taskse.exe, @WanaDecryptor@.exe)

- **taskdl.exe & taskse.exe:** Processi di servizio eseguiti ripetutamente in loop per mantenere attivo il processo dell'interfaccia grafica.
- **@WanaDecryptor@.exe (PID 4680, 412, 1404, ecc.):** Viene lanciato più volte con vari argomenti (es. co, vs) per mostrare costantemente a schermo la finestra rossa con il timer e la richiesta di riscatto in Bitcoin.

4. CONSIDERAZIONI FINALI

L'analisi ha permesso di scovare il tipo di malware e la famiglia di appartenenza WannaCry, uno dei programmi malevoli più conosciuti e devastanti della storia, confermato dal punteggio di pericolosità di 10/10. Dall'esame dei processi e comportamenti risulta essere un ransomware estremamente efficace, poiché è capace di ottenere i privilegi massimi accedendo così a tutti gli elementi presenti nel sistema incluse le copie di backup rendendo difficile il recupero delle informazioni. Oltre a cifrare tutti i dati crea anche nuove chiavi di registro per poter eseguire il codice malevolo ad ogni riavvio e per mostrare su desktop il banner con la richiesta di riscatto. Mantiene la comunicazione con il C2 tramite rete Tor per rendere l'occultamento più efficace e proteggere la posizione geografica della console di attacco oltre a rendere illeggibile i pacchetti a possibili intercettazioni.

L'indagine dinamica ha permesso di comprendere l'alto impatto che ha l'eseguibile scansionato sui sistemi attaccati, che vengono resi completamente inaccessibili grazie alle tecniche di crittografia e di persistenza. L'unico modo di contrastare questo pericolo è la consapevolezza, quando si naviga in rete o si ricevono risorse sospette come email di phishing. È estremamente importante anche avere sempre copie di backup conservate in infrastrutture a parte.